

CAPTURAS DE PANTALLA (EVIDENCIAS)

Estudiante: Iris Carolina Fernandez Gonzalez

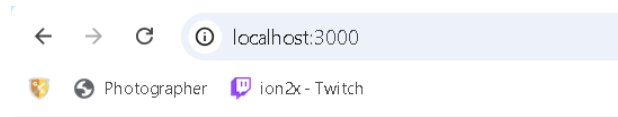
VULNERABLE:

1-Broken Authentication

Descripción: El sistema de autenticación no valida correctamente las credenciales.

Ejemplo de ataque: Acceso con credenciales incorrectas o manipuladas.

Resultado: Acceso no autorizado al sistema.



← → ↻ ⓘ localhost:3000

🛡️ Photographer 🗣️ ion2x - Twitch

euVWA vulnerable funcionando



← → ↻ ⓘ localhost:3000/login

🛡️ Photographer 🗣️ ion2x - Twitch

Login Vulnerable

Usuario:

Password:

Login

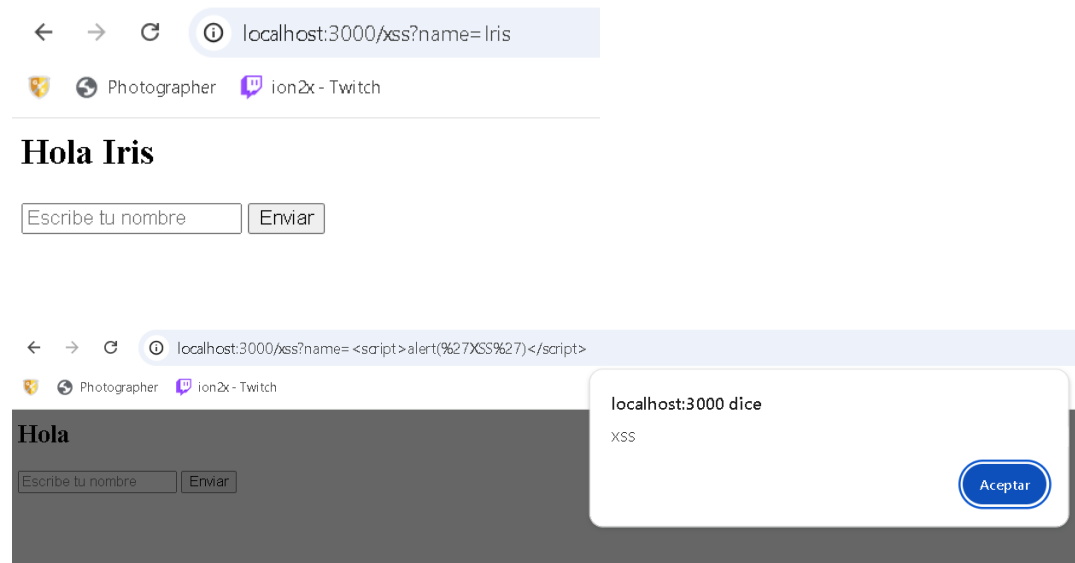
Hay 2 videos en la carpeta videos del proyecto.

2-.XSS Reflejado

Descripción: Se inyecta código JavaScript en un campo de entrada que es devuelto sin filtrar al navegador.

Ejemplo de ataque: `<script>alert('XSS')</script>`

Resultado: Se ejecuta un script en el navegador del usuario.

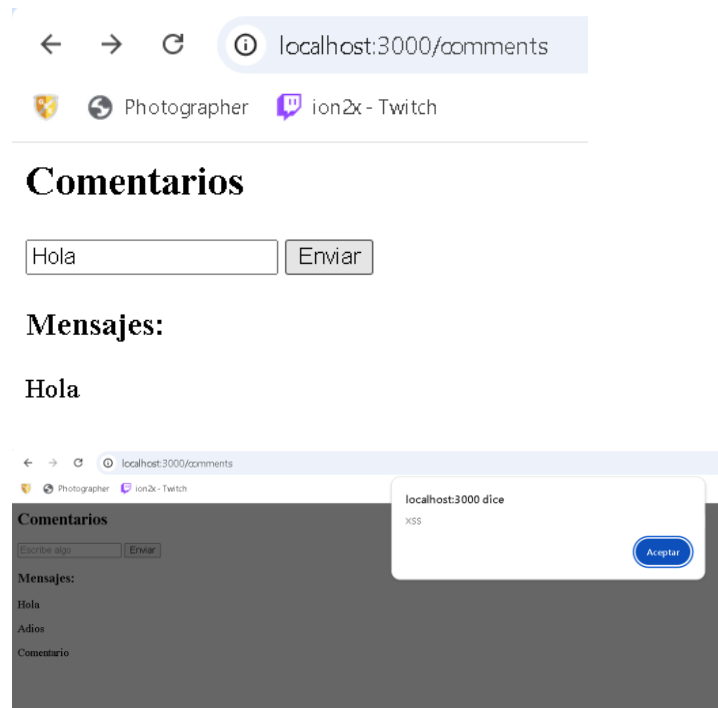


3-XSS Almacenado

Descripción: El código malicioso se almacena en el sistema y se ejecuta cuando se visualiza posteriormente.

Ejemplo de ataque: `<script>alert('Stored XSS')</script>`

Resultado: El script se ejecuta automáticamente al cargar la página.



Hay un video en la carpeta videos.

4-COMMAND INJECTION

Descripción: Permite ejecutar comandos del sistema operativo a través de la aplicación web.

Ejemplo de ataque: ; ls o && dir

Resultado: Se muestran resultados del sistema operativo, indicando ejecución de comandos.

```
localhost:3000/ping

Haciendo ping a 127.0.0.1 con 32 bytes de datos:
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128

Estadísticas de ping para 127.0.0.1:
  Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
  Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 0ms, Media = 0ms

Haciendo ping a 127.0.0.1 con 32 bytes de datos:
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128
Respuesta desde 127.0.0.1: bytes=32 tiempo<1m TTL=128

Estadísticas de ping para 127.0.0.1:
  Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
  Tiempos aproximados de ida y vuelta en milisegundos:
    Mínimo = 0ms, Máximo = 0ms, Media = 0ms
El volumen de la unidad C es Windows
El número de serie del volumen es: BC39-D647

Directorio de C:\Users\Mario\euVWA

09/05/2026 01:08 a.m.
.
09/05/2026 01:07 a.m.
..
09/05/2026 01:08 a.m.
  main-secure
09/05/2026 01:08 a.m.
    main-vulnerable
09/05/2026 01:07 a.m.
      node_modules
09/05/2026 01:07 a.m.                28,954 package-lock.json
09/05/2026 01:07 a.m.                319 package.json
                                2 archivos      29,273 bytes
                                5 dirs  135,951,568,896 bytes libres
```

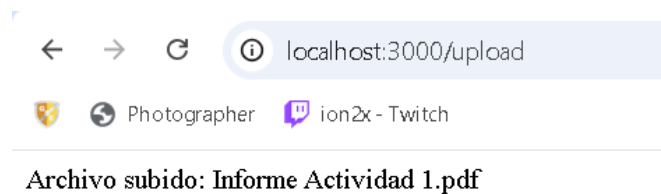
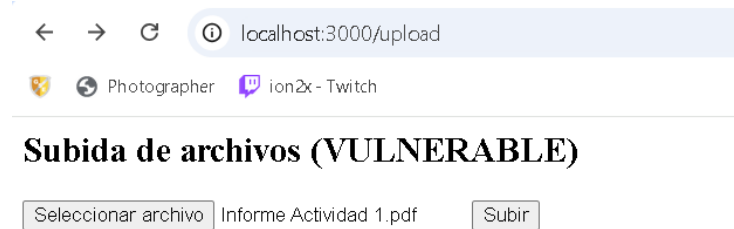
Hay 2 videos en la carpeta videos.

5-INSECURE FILE UPLOAD

Descripción: Permite subir archivos sin validar tipo o contenido.

Ejemplo de ataque: Subida de archivos no restringidos.

Resultado: Se acepta cualquier archivo, lo que puede permitir ejecución de código malicioso.



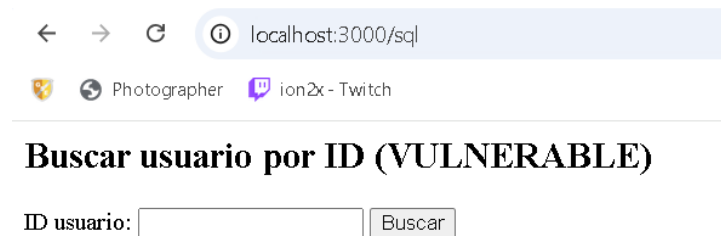
Hay 2 videos en la carpeta videos

6-SQL INJECTION

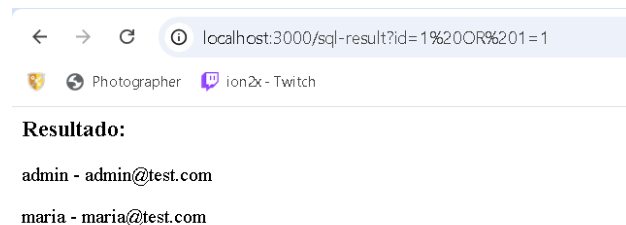
Descripción: Se explota manipulando la entrada del usuario para alterar la consulta SQL.

Ejemplo de ataque: OR 1=1

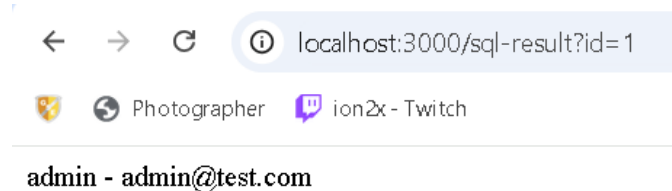
Resultado: Se obtienen todos los registros de la base de datos sin necesidad de autenticación.



A screenshot of a web browser window. The address bar shows 'localhost:3000/sql'. Below the address bar, there are two user avatars: 'Photographer' and 'ion2x - Twitch'. The main content area has the heading 'Buscar usuario por ID (VULNERABLE)'. Below this heading, there is a form with the label 'ID usuario:' followed by a text input field and a 'Buscar' button.



A screenshot of a web browser window showing the result of a SQL injection attack. The address bar shows 'localhost:3000/sql-result?id=1%20OR%201=1'. Below the address bar, there are two user avatars: 'Photographer' and 'ion2x - Twitch'. The main content area has the heading 'Resultado:'. Below this heading, there is a list of two users: 'admin - admin@test.com' and 'maria - maria@test.com'.



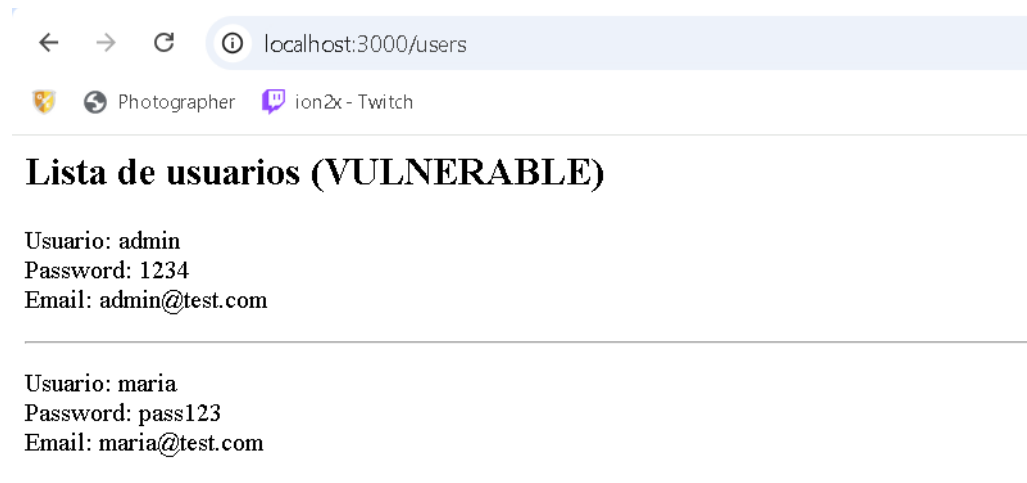
A screenshot of a web browser window showing the result of a SQL injection attack. The address bar shows 'localhost:3000/sql-result?id=1'. Below the address bar, there are two user avatars: 'Photographer' and 'ion2x - Twitch'. The main content area shows the text 'admin - admin@test.com'.

7-Sensitive Data Exposure

Descripción: Se exponen datos sensibles sin protección adecuada.

Ejemplo de ataque: Acceso directo a información sensible en la aplicación.

Resultado: Visualización de datos confidenciales.

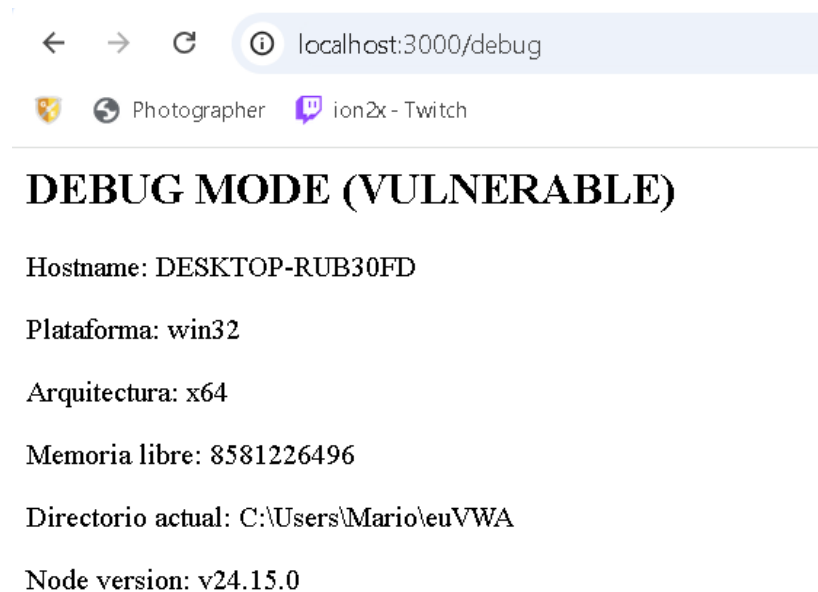


8-Security Misconfiguration

Descripción: La aplicación muestra información interna del sistema o errores detallados.

Ejemplo de ataque: Provocar un error en la aplicación.

Resultado: Se muestran mensajes de error con información sensible del servidor.



SECURE

1- Broken Authentication

← → ↻ ⓘ localhost:3000/login

🛡️ 🌐 Photographer 🗨️ ion2x - Twitch

Login SECURE

Usuario:

Password:

Login

2- XSS Reflejado

← → ↻ ⓘ localhost:3000/xss

🛡️ 🌐 Photographer 🗨️ ion2x - Twitch

XSS SEGURO

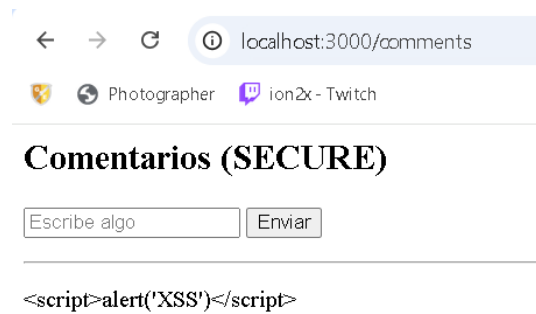
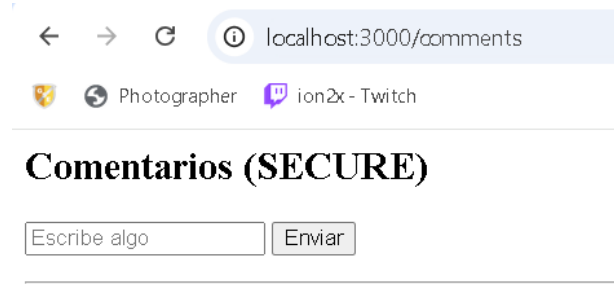
Nombre: Enviar

← → ↻ ⓘ localhost:3000/xss-result?name= <script>alert%28%27XSS%27%29<%2Fscript>

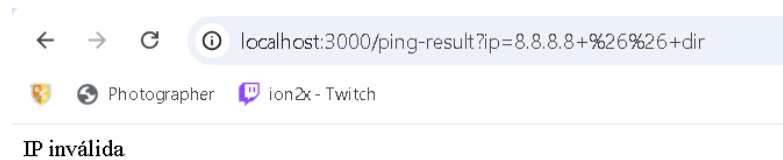
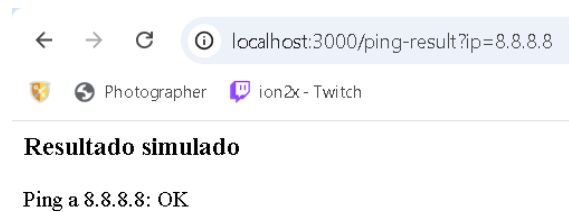
🛡️ 🌐 Photographer 🗨️ ion2x - Twitch

Hola <script>alert('XSS')</script>

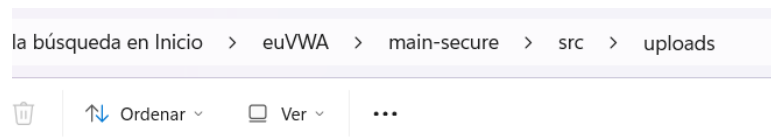
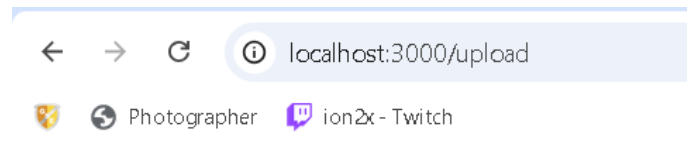
3- XSS Almacenado



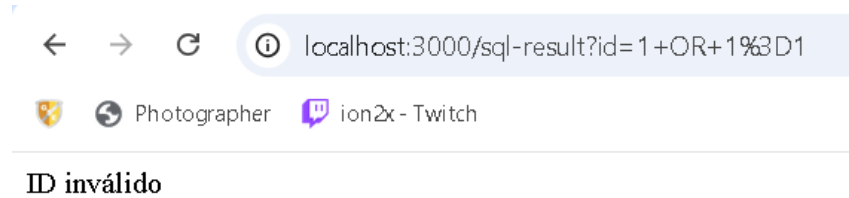
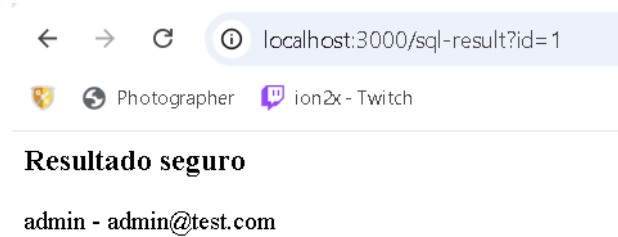
4- Command Injection



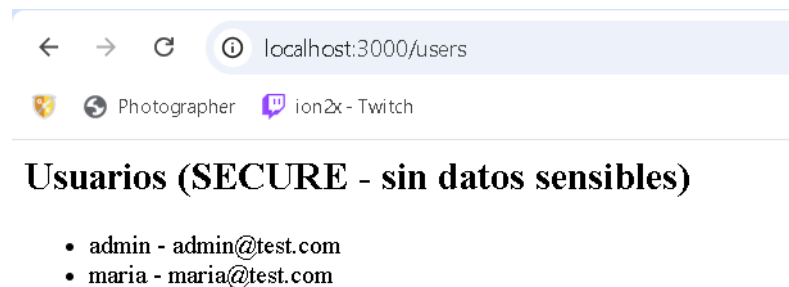
5- Insecure File Upload



6- SQL Injection



7- Sensitive Data Exposure



8- Security Misconfiguration

